



Human and Physical Aspects of Security

Threat Model of a Drone Delivery System Using STRIDE

Author(s): **Matteo Lo Giudice (10829241)**

Matteo Bregola (11095785)

Dario Antonino Santo (10733108)

Professor: **Stefano Longari, Balossini Marco**

Contents

Contents	i
List of Acronyms	ii
1 Description of the analyzed scenario	1
1.1 System Overview	1
1.2 Mission Lifecycle	2
1.3 Premises and Scope Decisions	3
1.4 Adversary Model	4
2 Data Flow Diagram	6
2.1 Assets	6
2.2 Actors, Processes, Data Stores and External Entities	8
2.3 Trust Boundaries	9
3 Threat Identification and Risk Assessment	11
3.1 STRIDE Methodology	11
3.2 Risk Assessment Scoring Methodology	11
4 Conclusion	26
A Appendix A	28
List of Figures	39
Bibliography	40

List of Acronyms

Acronym	Definition
ADS-B	Automatic Dependent Surveillance–Broadcast
AGL	Above Ground Level
API	Application Programming Interface
ATC	Air Traffic Control
BVLOS	Beyond Visual Line-of-Sight
CAM	Continued Airworthiness Management
CIA	Confidentiality, Integrity, Availability
CONOPS	Concept of Operations
DAA	Detect-and-Avoid
DB	Database
DFD	Data Flow Diagram
ESC	Electronic Speed Controller
FAA	Federal Aviation Administration
GCS	Ground Control Station
GDPR	General Data Protection Regulation
GLONASS	Globalnaya Navigatsionnaya Sputnikovaya Sistema
GNSS	Global Navigation Satellite System
GPS	Global Positioning System
HMI	Human-Machine Interface
HTTPS	Hypertext Transfer Protocol Secure
HW	Hardware
IDS	Intrusion Detection System
IMU	Inertial Measurement Unit
JTAG	Joint Test Action Group
LiDAR	Light Detection and Ranging
LTE	Long-Term Evolution
MFA	Multi-Factor Authentication
MITM	Man-in-the-Middle
mTLS	Mutual Transport Layer Security
NAS	National Airspace System
OIC	Operator-In-Charge
OTA	Over-The-Air
PII	Personally Identifiable Information

Acronym	Definition
RBAC	Role-Based Access Control
RF	Radio Frequency
RSSI	Received Signal Strength Indicator
RTB	Return-To-Base
SAA	Sense-and-Avoid
SDR	Software-Defined Radio
SNR	Signal-to-Noise Ratio
STRIDE	Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege
SWD	Serial Wire Debug
TLS	Transport Layer Security
UA	Unmanned Aircraft
UART	Universal Asynchronous Receiver-Transmitter
UAS	Unmanned Aircraft System
UTM	UAS Traffic Management
VTOL	Vertical Take-Off and Landing

1 | Description of the analyzed scenario

1.1. System Overview

This threat model analyses **Amazon Prime Air**, Amazon's autonomous drone delivery service. Prime Air uses unmanned aircraft systems (UAS) to deliver parcels of up to 5 pounds within 30 minutes of order placement [1]. The aircraft under analysis is the Amazon-designed **MK27**, a fixed-wing platform capable of vertical take-off and landing (VTOL) and wing-borne flight.

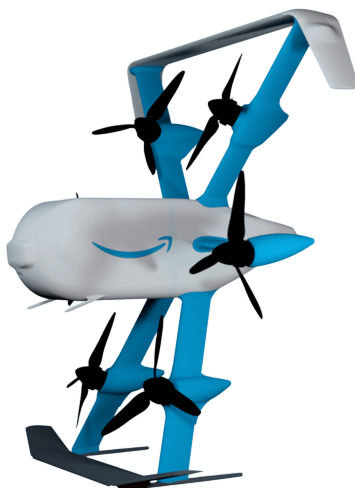


Figure 1.1: Amazon Prime Air Drone.

Operations are conducted Beyond Visual Line-of-Sight (BVLOS) and rely on a combination of foundational UAS Traffic Management (UTM) infrastructure, onboard Sense-and-Avoid (SAA) capabilities, coordination with local Air Traffic Control (ATC) facilities, and pre-flight screening of the flight area.

Flights are fully autonomous from the point of launch. As defined in Amazon's CONOPS, the Operator-In-Charge (OIC) does not directly control the aircraft; rather, the OIC operates in a management-by-exception role, monitoring telemetry, airspace, and weather conditions and issuing high-level directives — such as *return-to-base* or *land-safely-now* — only upon off-nominal events. The MK27 is further designed to execute automated separation and safe-landing maneuvers without operator intervention, including in the event of a complete lost-link scenario.

1.2. Mission Lifecycle

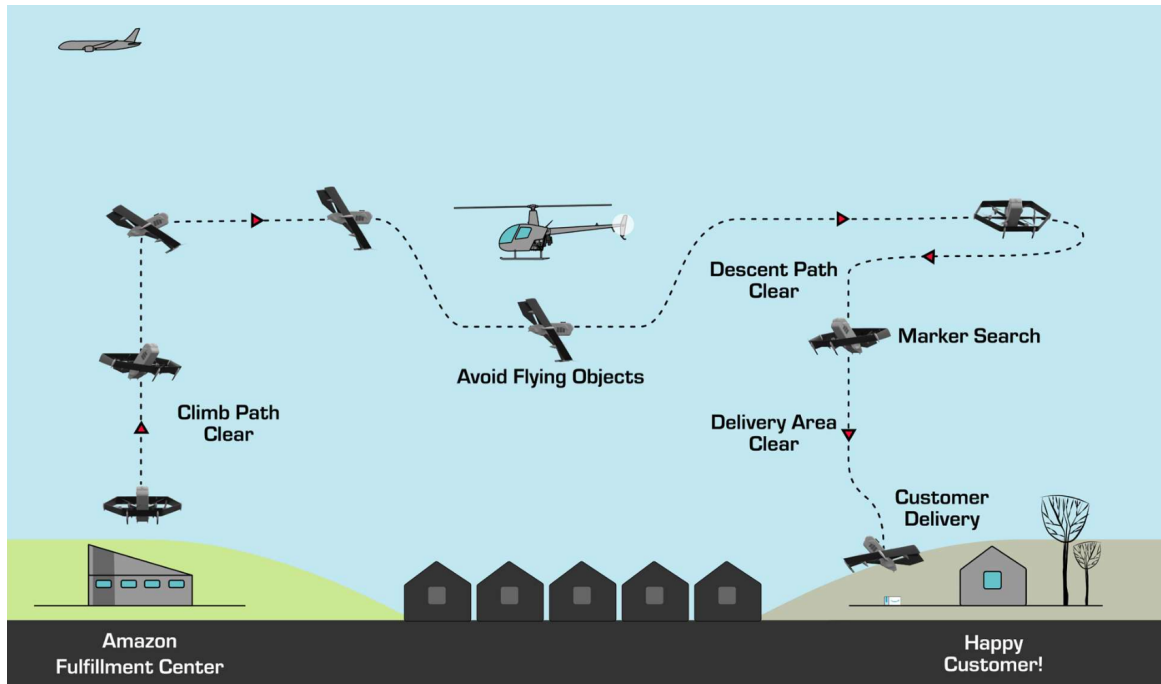


Figure 1.2: Amazon Prime Air Mission Lifecycle Diagram. Source: [1].

1. **Pre-Flight:** UTM computes a 4D trajectory (3D + time) based on customer delivery location, package weight, environmental conditions, air-traffic and airspace constraints, and take-off/landing constraints. A flight assistant performs pre-flight inspection and airworthiness verification.
2. **En-Route:** The UA departs the Amazon facility, transitions to cruise altitude (≤ 400 ft AGL), and proceeds along the planned route. Separation assurance is provided by a layered combination of onboard SAA, UTM (which ingests ADS-B traffic data and ATC feeds), and full-duplex GCS $\leftrightarrow$ ATC communications.
3. **Command and Control:** Command links use redundant beyond-radio-line-of-sight infrastructure (e.g. LTE cellular). Real-time UA identification and tracking are made available to the responsible FAA ATC facility. Critical control is not interactive: the UA's automated fail-safe handles degraded communications.
4. **Delivery:** Upon arrival, the UA transitions to vertical flight, identifies the delivery area via a unique marker, performs a clear-area assessment with onboard sensors, descends to a safe delivery height, hovers, releases the package, and departs. Fail-safe logic aborts the delivery and returns the drone to base if any obstruction is detected.
5. **Continued Airworthiness:** Onboard health-monitoring systems perform real-time diagnostics. Post-flight inspection and maintenance triage (CAM — Continued Airworthiness Management) gate re-dispatch.

1.3. Premises and Scope Decisions

To keep the analysis tractable and focused on the drone-specific attack surface, the following scoping decisions were adopted:

- **Account authentication and authorization** (token issuance, account-level credential management) are considered out-of-scope. While account compromise is a plausible attack precursor, threats specifically tied to UAS operations are more relevant to the analyzed scenario. Operator credentials themselves remain in-scope as an asset (*Credentials*).
- **The OIC is modelled in the pre-flight (load and dispatch) phase only**, not during en-route control. Amazon’s CONOPS states that the OIC does not interactively pilot the UA: “*there are no circumstances in which the OIC would need to remotely intervene to directly control the UA’s flight control system*”, and “*the MK27 is designed to perform an automated response maneuver [...] without the need for any operator intervention*”. The OIC therefore appears as an actor with an HMI interaction with the GCS for pre-flight checks; threats targeting OIC interactive intervention during flight are excluded as inapplicable to the modelled CONOPS.
- **ATC↔GCS direct communication is collapsed into ATC → Drone → GCS** for model simplification. Amazon documents a redundant ATC↔OIC communication path. We treat air-traffic data as flowing from ADS-B to the drone (via the UTM System), so the ATC↔GCS channel is folded into existing paths to avoid model redundancy. This is a deliberate simplification: in production, the parallel channel would provide additional resilience and should be considered when assessing residual risk.
- **ATC is classified as Semi-trusted, not Trusted.** Although the FAA-operated ATC institution itself is trusted, the radio channels it uses (notably ADS-B on 1090 MHz) are unauthenticated and unencrypted by international aviation standard. Anyone with a software-defined radio can read and inject ADS-B traffic. Treating the ATC trust boundary as Semi-trusted reflects the channel reality and forces explicit cross-validation in the threat analysis.
- **Mission Plan is not modelled as an independent asset.** The mission plan is generated inside the system as a derivative of User Data and Order Details by the UTM System. Confidentiality and integrity of the mission plan are protected through the underlying asset protection (*User Data*) and by the threats explicitly modelled on the data flows that carry it. This mirrors the pattern used in analogous services (e.g. session tokens in web applications are typically not modelled as independent assets but as derivatives of authentication assets).
- **Inter-drone communication and drone-fleet-to-ATC communication are out of scope.** The Drone Fleet is represented on the diagram inside an explicit Out-of-

Scope trust boundary, with the related flows excluded from threat enumeration. Attacks on inter-drone deconfliction or fleet-level coordination would warrant a separate analysis with its own attacker model.

- **Continued Airworthiness Management (CAM) is treated as embedded in the GCS and Drone Controller.** Post-flight inspection results and maintenance gating are captured through threats on the GCS pre-flight workflow (#22 — Workstation Intrusion) and on the Drone Controller (#18 — Unauthorized Access). A separate CAM process node was not added to keep the diagram readable.
- **Mitigations are proposed against a best-practice baseline.** Amazon likely already implements many of them in production; without access to a confidential security assessment we err on the side of completeness, including baseline controls (TLS, MFA, etc.) for documentary thoroughness.

1.4. Adversary Model

Threats are evaluated against the following attacker archetypes. The list is ordered by capability and access, most attacker archetypes can in principle execute most threats.

- **Casual eavesdropper / hobbyist.** Budget €20–€500, commodity SDR/jammer kit, public tutorials. Targets ADS-B and other unprotected RF channels (threats #13, parts of #14). Cannot reliably mount active attacks but is the dominant population on ADS-B reconnaissance.
- **Opportunistic parcel thief.** Moderately resourced, motivated by cash value of intercepted parcels. Typical capabilities: public Wi-Fi MITM tools, neighbourhood-level physical presence at delivery time, ability to print or display a fake delivery marker. Primary archetype behind threats #11, #19, #23.
- **Local RF attacker.** Owns a commodity jammer (GPS, RF, ADS-B). Active interference against deliveries, navigation, or detect-and-avoid (threats #1, #2, #3, #8). The motivation may be theft (chained to #23), denial of service, or simple vandalism.
- **Malicious insider — OIC or GCS operator.** Has legitimate but limited access to the GCS or the OIC workstation. May escalate privileges (#17) or abuse delegated authority — including the pre-flight checklist (#22). This archetype is the highest-leverage internal threat because it bypasses most network-level defences.
- **Remote attacker against credentials and endpoints.** Targets the OIC workstation, GCS accounts, or backend mTLS certificates via phishing, malware, or supply-chain compromise. Drives threats #5, #17, #22. The *Credentials* asset is the linchpin: most other defences collapse if credentials are stolen.

- **Sophisticated remote attacker.** Targets the drone controller firmware (#18) and onboard buses (#15, #16) via exposed interfaces, weak update mechanisms, or physical access during maintenance. Requires reverse-engineering capabilities. Single-airframe damage is high; cascading to fleet level if a vulnerability is exploitable via OTA, which is captured indirectly as a multiplier on #18.
- **Nation-state or industrial / well-resourced threat actor.** Capable of advanced GPS spoofing (gradual, multi-constellation), ADS-B injection at scale, supply-chain compromise of airframes or firmware. Not the primary likelihood basis but considered for Critical-severity threats and worst-case impact scoring.

2 | Data Flow Diagram

The system was modelled in OWASP Threat Dragon v2.6.2 using the STRIDE methodology. The diagram below was exported from Threat Dragon.

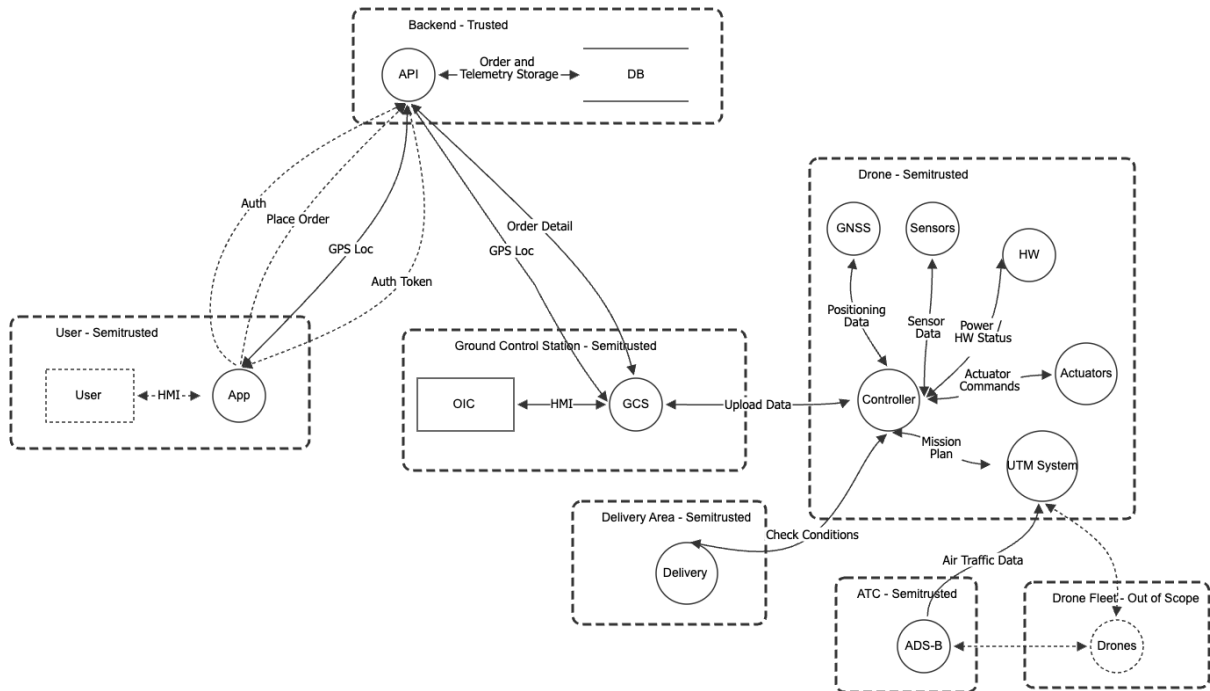


Figure 2.1: Threat Model Visual Representation

2.1. Assets

The following assets were identified as the targets of protection.

Asset	Description and rationale
User Safety	Bodily safety of the customer, residents at the delivery location, and any person/pet in close physical proximity to the drone during delivery. Endangered by uncontrolled crashes, premature payload release, hard landings, or unsafe maneuvers near the ground.

Asset	Description and rationale
NAS Safety	Safety of the National Airspace System: other aircraft (manned and unmanned), other airspace users, and the integrity of detect-and-avoid behaviour. Distinct from User Safety because attacks on ADS-B, ATC, or DAA primarily endanger third parties in the airspace, not the customer at the delivery location.
Drone	The fleet of MK27 airframes, considered as a unified asset. Includes both individual airframes (single-mission compromise) and the fleet as a whole (scalable attacks via OTA, supply chain, or shared vulnerabilities). Fleet availability is captured within this asset rather than as a separate one.
Delivery Parcels	The physical goods being transported. Loss, theft, or misdelivery directly impacts this asset.
User Data	Customer PII: name, address, delivery location, order history, contact information. Subject to GDPR and similar regulatory frameworks. The Mission Plan is generated from this asset (plus Order Details) and is treated as derivative — its protection is achieved through this asset's protection.
User Satisfaction	Customer experience and trust in the service. Repeated delivery failures, visible incidents, or denied deliveries degrade this asset even without safety events.
Brand Reputation	Public perception of Amazon Prime Air specifically and Amazon as a whole. A single high-visibility incident has a large multiplicative effect.
Environment Safety	Safety of the physical environment along the flight route: vehicles, buildings, urban infrastructure, the natural environment. Endangered by uncontrolled crashes outside the delivery zone or large-scale payload release.
FAA Certification	Amazon's regulatory authorization to operate Prime Air under FAA Part 135 / Part 137 (and emerging Part 108) frameworks. A safety event or systemic vulnerability disclosure can trigger regulatory inquiry, fines, or operational suspension. Acts as a long-term severity multiplier on safety-related threats.
Credentials	All Amazon-controlled access credentials in scope: GCS operator accounts, OIC workstation credentials, mTLS client certificates, firmware signing keys, API tokens used by the drone and the GCS. Compromise of these meta-assets unlocks many of the high-severity threats below.

2.2. Actors, Processes, Data Stores and External Entities

Element	DFD Type	Description
User	External entity (Actor)	Customer placing the order, interacting via the mobile app, and receiving the delivery.
OIC	Actor (internal)	Operator-In-Charge: supervises pre-flight inspection and airworthiness verification via the GCS HMI; monitors missions in a management-by-exception model during flight (per CONOPS, no interactive control of the UA).
App	Process	Mobile application: order placement, authentication, real-time tracking, delivery notification.
API	Process	Backend API surface: orchestrates order processing, mission assignment, telemetry distribution, and persistence.
DB	Data Store	Backend database: orders, customer data, telemetry archive, mission history.
GCS	Process	Ground Control Station: HMI for the OIC; mission supervision; command relay. CAM gating responsibilities are embedded in the GCS pre-flight workflow.
Controller	Process	Drone Flight Controller (onboard): sensor fusion, flight control loops, mission state machine, safety logic. CAM diagnostic functions are embedded in the controller's health monitoring.
UTM System	Process	UAS Traffic Management: route planning, 4D trajectory computation, dynamic airspace deconfliction. In this model the UTM System is the consumer of ATC/ADS-B feeds (rather than the Controller directly).
Sensors	Process	Onboard sensor suite: IMU, barometer, magnetometer, cameras, obstacle detection, altimeter.
Actuators	Process	Motor ESCs, servos, payload-release mechanism — execute physical control commands.
GNSS	Process	Onboard GNSS receiver: GPS (primary), Galileo / GLONASS / BeiDou for multi-constellation positioning.

Element	DFD Type	Description
ADS-B	Process	Automated Dependent Surveillance-Broadcast receiver for traffic awareness from manned and unmanned aircraft. Feeds the UTM System.
Delivery	Process	Delivery-area assessment subsystem: marker recognition, clear-area check, descent decision, payload release.
HW	Process	Hardware abstraction layer between Controller and physical resources (power management, drivers, ESC bus).
ATC	External entity	Air Traffic Control authority external to the Prime Air system. Provides airspace and traffic-related information to the UTM System for route planning, separation assurance, and dynamic airspace awareness. Modelled as an external entity because it is not operated by Amazon but communicates with the system through ATC/ADS-B feeds.
Drones	Process (out of scope)	The wider drone fleet for inter-drone communication and fleet-level coordination. Modelled on the diagram but explicitly out of scope for threat enumeration in this iteration.

2.3. Trust Boundaries

Trust Boundary	Classification	Contains / Rationale
Backend	Trusted	API, DB. Amazon-controlled cloud infrastructure with strong perimeter controls, network segmentation, identity and access management, and continuous monitoring. The only “Trusted” boundary in the model.
Ground Control Station	Semi-trusted	GCS workstation and OIC actor. Amazon-controlled but exposed to insider threat, workstation malware, credential theft, and unauthorized physical access. Treated Semi-trusted because the human element and endpoint exposure cannot be fully eliminated.

Trust Boundary	Classification	Contains / Rationale
Drone	Semi-trusted	Controller, GNSS, Sensors, Actuators, UTM System, HW, ADS-B receiver. Amazon-controlled airframe but exposed physically (each flight reaches a customer location) and over-the-air (RF channels for command, telemetry, ADS-B, GPS).
ATC	Semi-trusted	FAA-operated air traffic control system. The institution itself is trusted, but the actual radio channels (ADS-B at 1090 MHz) are broadcast in clear and unauthenticated by international aviation standard. Anyone with a software-defined radio can read and inject ADS-B messages. Downgraded from Trusted to Semi-trusted in this iteration to reflect channel reality.
Delivery Area	Semi-trusted	Customer's location during delivery. Physically uncontrolled; subject to local jamming, marker spoofing, or pedestrian/pet incursions. Trusted insofar as it is the intended destination, semi-trusted because the surrounding physical environment is not under Amazon's control.
User	Semi-trusted	User App on user device. Trusted as legitimate customer endpoint but network path may traverse untrusted Wi-Fi or malicious proxies, and the device itself is outside Amazon's control.
Drone Fleet	Out of Scope	Wider fleet of drones for inter-drone communication and fleet-level coordination. Represented on the diagram with a dotted border to signal explicit exclusion from threat enumeration in this iteration.

3 | Threat Identification and Risk Assessment

3.1. STRIDE Methodology

Threats were identified using the STRIDE methodology (**S**poofing, **T**ampering, **R**epudiation, **I**nformation Disclosure, **D**enial of Service, **E**levation of Privilege). The 23 threats below cover all six STRIDE categories. For each threat we report: STRIDE category, affected component/communication, attacker access level required, full description, impact, affected security properties (CIA + authenticity/non-repudiation), assets at risk, severity rationale, and mitigation. [3]

3.2. Risk Assessment Scoring Methodology

The risk assessment uses three qualitative scales: a *Likelihood* of occurrence, an *Impact* on the system if the threat materialises, and a *Risk Score* that combines the two in a single prioritisation metric.

3.2.1. Likelihood Scale:

Level	Rationale
Frequent	The event already occurred several times and it may re-occur in the immediate future.
Occasional	The event already occurred in the recent past and it may represent in the near future.
Uncommon	The event did not occur yet and it may occur in the future.
Rare	The event did not occur in the past and it is not expected to manifest in the future.

3.2.2. Impact Scale:

The impact scale is harmonised on four levels — Low, Medium, High, Critical — to align it with the Risk Score scale defined below and to enable a meaningful combination of the two dimensions in the risk matrix.

Level	Rationale
Critical	The event causes a safety incident, a regulatory enforcement action, or a systemic operational outage; the consequence is largely irreversible (e.g. injury to persons, suspension of FAA authorisation, fleet-wide compromise).
High	The event results in operational blocks and in significant economic, regulatory or reputational impact, but without an irreversible safety consequence.
Medium	The event results in operational slowdowns or in localised damage with a relevant economic or reputational impact bounded to a subset of customers or missions.
Low	The event causes only slight impacts on the regular proceeding of operations, with no safety, regulatory, or material reputational consequence.

3.2.3. Risk Score

The Risk Score expresses the priority that a given threat should receive in the mitigation roadmap. It uses the qualitative scale Low – Medium – High – Critical and is **derived deterministically from the Likelihood and Impact ratings** through the matrix below.

Likelihood ↓ / Impact →	Low	Medium	High	Critical
Frequent	Medium	High	Critical	Critical
Occasional	Low	Medium	High	Critical
Uncommon	Low	Medium	High	Critical
Rare	Low	Low	Medium	High

Table 3.3: Risk Score derivation matrix.

The four Risk Score levels carry the following operational meaning:

- **Critical** — the threat must be mitigated as a precondition for safe operation; residual risk is unacceptable. Treated in this chapter.
- **High** — the threat must be mitigated as part of the baseline security posture; residual risk is acceptable only with compensating controls. Treated in this chapter.

- **Medium** — the threat should be mitigated using best-practice controls. Treated in Appendix A.
- **Low** — the threat is acknowledged and tracked; mitigation is opportunistic. Treated in Appendix A.

This report follows the inherent-risk convention: the Likelihood and Impact ratings are assessed against the system as modelled in the DFD, *before* application of the mitigations proposed in this chapter and in the Appendix. Where Amazon’s CONOPS already provides a native compensating control (e.g. multi-constellation GNSS for Threat #4), the rationale of the affected threat notes that the residual risk is materially reduced relative to the inherent score.

Threat #1 — RF Jamming — GCS↔Drone Command & Telemetry Link

Threat #1 — RF Jamming — GCS↔Drone Command & Telemetry Link	
STRIDE Category	Denial of Service
Attacker Access Required	Physical proximity to drone operational corridor (~hundreds of meters); commodity RF jammer (€50–€500).
Affected Properties	Availability, Integrity
Assets at Risk	Drone, Delivery Parcels, User Satisfaction, Brand Reputation

Description An attacker with RF transmission capability near the drone, the GCS, or the communication path between them transmits interference on the same or overlapping frequency bands used for the command-and-control link. As a result, the drone controller cannot reliably receive commands from the GCS, or the GCS cannot receive telemetry. The drone loses operator supervision, fails to receive emergency commands, triggers fail-safe return-to-home or safe-landing procedures, and the delivery is aborted.

Impact Mission abort, return-to-base, delivery delay or failure. Without redundant control link, operational safety is degraded. Repeated targeted jamming events can degrade fleet availability across affected geographies.

Risk Assessment Likelihood: **Occasional** Impact: **High** Risk Score: **High**

Rationale: *Commodity jammer attacks are observed in the wild against drone systems. Impact reaches High because of degraded operational availability, but is contained by Amazon’s autonomous fail-safe (RTB). No safety event in itself, but a denial-of-delivery at scale damages brand and customer satisfaction.*

Mitigation Use resilient communication mechanisms for the GCS–drone link: frequency hopping, spread spectrum, adaptive channel switching, directional antennas, and redundant communication paths (e.g. LTE + dedicated radio). The drone monitors link-quality indicators (RSSI, SNR, packet loss, latency, command timeout rates) to detect jamming or severe interference. On link loss the drone enters a predefined fail-safe mode: hold position where safe, return to base, land at a safe area, or continue only a strictly validated autonomous segment depending on mission policy. Critical safety actions must be executable locally without continuous GCS connectivity. All link-loss and suspected-jamming events are logged and reported to the backend/GCS for investigation.

Threat #4 — GPS Spoofing

Threat #4 — GPS Spoofing	
STRIDE Category	Spoofing
Attacker Access Required	Software-defined radio (HackRF, BladeRF — €300–€2,500), GPS-SDR-SIM tools, antenna in operational area.
Affected Properties	Integrity, Authenticity
Assets at Risk	Drone, Delivery Parcels, NAS Safety, User Safety, Brand Reputation

Description An attacker transmits forged GPS-like signals near the drone’s operating area, making the controller believe that the drone is located somewhere different from its real physical position. The attacker may gradually manipulate the perceived location, altitude, speed, or route progress so that the controller trusts false navigation data. The drone may deviate from the planned route, fly toward an attacker-controlled location, miss the intended delivery area, incorrectly trigger geofence or return-to-home logic, or expose the package to theft or loss.

Impact Route deviation, potential delivery hijack, environmental safety event if the drone is steered into a restricted area. Inherent damage is severe; residual damage is reduced — but not eliminated — by Amazon’s sensor-fusion backup, especially under gradual or sub-threshold spoofing.

Risk Assessment Likelihood: **Uncommon** Impact: **High** Risk Score: **High**

Rationale: GPS spoofing requires SDR capability and operational know-how, so it is less commodity than jamming, but feasible. Damage is severe because navigation integrity drives every safety-critical decision; mitigated significantly by Amazon’s multi-constellation GNSS and sensor fusion, but gradual spoofing can remain under detection thresholds, justifying High.

Mitigation The controller does not rely solely on GPS for navigation and delivery decisions. Validate GPS readings via sensor fusion with IMU, barometer, magnetometer, visual odometry, obstacle sensors, geofencing, and expected mission route. Apply plausibility checks for impossible position jumps, unrealistic speed or altitude changes, inconsistent heading, abnormal satellite count, signal-strength anomalies, and divergence between GPS and other sensors. Use multi-constellation GNSS (GPS + Galileo + GLONASS + BeiDou) and GPS anti-spoofing detection where available. On suspected spoofing the drone rejects suspicious GPS updates and enters a safe fallback mode: slow down, hover where safe, request GCS confirmation, return to base using alternative navigation, or perform a controlled safe landing. Log all suspected-spoofing events with timestamp, location, signal-quality indicators, and mission context.

Threat #5 — Spoofing of Delivery Details inside GCS

Threat #5 — Spoofing of Delivery Details inside GCS	
STRIDE Category	Spoofing
Attacker Access Required	Compromised GCS workstation, stolen operator credentials, malicious insider, or malware on GCS host.
Affected Properties	Integrity, Confidentiality, Authenticity
Assets at Risk	Delivery Parcels, User Data, Brand Reputation, User Safety, Drone, FAA Certification, Credentials

Description An attacker with access to the GCS environment — through a compromised workstation, malicious insider, stolen operator credentials, or malware installed on the GCS — spoofs the source or content of delivery details and inserts false delivery information directly into the GCS. The attacker may make the GCS believe that a forged delivery destination, package instructions, order identifier, or mission parameters originate from a trusted backend or authorized operator. The GCS may then process and execute a fraudulent delivery mission, causing the drone to deliver the package to the wrong location, expose customer goods to theft, or create disputes between the customer and the delivery provider.

Impact Fraudulent mission execution; package delivered to attacker; brand and trust damage; potential safety implications if forged destination is unsafe (e.g. crowded area or restricted airspace); plausible regulatory inquiry if pattern observed.

Risk Assessment Likelihood: **Uncommon** Impact: **Critical** Risk Score: **Critical**

Rationale: Requires either insider access or successful workstation compromise plus lateral movement, therefore not trivial and likelihood remains Uncommon. However, damage spans

every operational dimension including delivery integrity, customer trust, safety, and regulatory exposure; impact is High and severity becomes Critical. This represents one of the worst downstream effects of credential and workstation security failure.

Mitigation Require strong authentication and authorization for all GCS users and services: multi-factor authentication for operators, RBAC, least privilege, and separation of roles between mission viewing and mission modification. The GCS accepts delivery details only if digitally signed by the Backend API and verifies signature, timestamp, mission identifier, and sequence number before applying them. Validate delivery details against the original order, assigned drone, expected delivery area, and backend mission state. Critical changes to destination or mission parameters require re-authentication, audit logging, and — where appropriate — approval from a second authorized operator. Harden the GCS workstation through patching, malware monitoring, endpoint protection, and prevention of unauthorized local access.

Threat #6 — MITM — GPS Retrieval (GCS ↔ Backend)

Threat #6 — MITM — GPS Retrieval (GCS ↔ Backend)	
STRIDE Category	Tampering
Attacker Access Required	Network path between Backend and GCS: compromised network segment, malicious gateway, weak transport security, or insider access to communication infrastructure.
Affected Properties	Integrity, Availability
Assets at Risk	Brand Reputation, User Satisfaction, Delivery Parcels, User Data

Description An attacker positioned between the GCS and the Backend API — through a compromised network path, malicious gateway, weak transport security, or compromised GCS communication network — performs a Man-in-the-Middle attack and modifies the GPS coordinates exchanged between Backend and GCS. The GCS may consume false telemetry and present incorrect tracking information to operators; the backend may store, process, and downstream-distribute corrupted coordinates to the user-facing application.

Impact Tampered telemetry; corrupted data shown to users and operators; downstream theft, delivery disputes, and erosion of customer trust.

Risk Assessment Likelihood: **Uncommon** Impact: **High** Risk Score: **High**

Rationale: Backend infrastructure is internal and comparatively well defended, therefore the attack requires meaningful capability and likelihood remains Uncommon. However, damage

reaches High because corrupted telemetry propagates to multiple downstream consumers and may enable targeted theft or operational deception.

Mitigation Protect GCS–Backend API communication using HTTPS/TLS or mutual TLS with strict certificate validation and device-bound certificates for the GCS. GPS telemetry messages must be integrity protected through signed payloads or message authentication codes, timestamps, sequence numbers, and short validity windows to prevent modification or replay. The backend rejects stale, unsigned, duplicated, or inconsistent telemetry updates. Coordinates are validated against the expected mission route, delivery geofence, drone speed limits, order state, and recent telemetry history before being forwarded to users. Suspicious deviations or inconsistent GPS updates are logged and trigger security alerts.

Threat #10 — ADS-B Message Spoofing

Threat #10 — ADS-B Message Spoofing	
STRIDE Category	Spoofing
Attacker Access Required	Software-defined radio (HackRF, RTL-SDR — €30–€500); ADS-B has no native cryptographic authentication.
Affected Properties	Integrity, Authenticity
Assets at Risk	Drone, NAS Safety, Delivery Parcels, Brand Reputation

Description An attacker transmits crafted ADS-B messages using low-cost RF equipment or software-defined radio and spoofs aircraft or air-traffic broadcasts received by the drone’s ADS-B receiver and consumed by the UTM System. The controller may believe that a non-existent aircraft is nearby, that a real aircraft is in a different position, or that false altitude, speed, identity, or navigation data is legitimate. The drone may therefore make incorrect detect-and-avoid or route-planning decisions, including unnecessary evasive maneuvers, route deviation, mission delay, unsafe behavior, or denial of normal delivery service.

Impact Forced evasive maneuvers, mission delay, and route deviation. Worst case: unsafe maneuver near ground obstacles or other aircraft, indirectly endangering NAS users and operational safety.

Risk Assessment Likelihood: **Occasional** Impact: **High** Risk Score: **High**

Rationale: *ADS-B is unauthenticated by international aviation standards, and SDR-based spoofing attacks are documented in academic literature. Damage reaches High because detect-and-avoid logic is safety critical for both the drone and other airspace users.*

Mitigation The controller does not blindly trust ADS-B messages as the sole source of air-traffic awareness. Validate ADS-B data against additional sources including UTM data, on-board sensors, expected airspace constraints, previous message history, and trajectory plausibility checks. Detect impossible or suspicious values such as sudden position jumps, unrealistic speed or altitude changes, duplicate aircraft identifiers, or ghost aircraft appearing only briefly. Apply freshness checks, rate limiting, and anomaly detection on received ADS-B messages. When ADS-B data is inconsistent or suspicious, the drone enters a conservative safety mode, reduces speed, requests confirmation from GCS or UTM, or follows predefined safe-routing behavior.

Threat #11 — MITM — GPS Retrieval (User App ↔ Backend)

Threat #11 — MITM — GPS Retrieval (User App ↔ Backend)	
STRIDE Category	Tampering
Attacker Access Required	Untrusted Wi-Fi network, compromised user network path, malicious proxy, or exploitation of weak TLS/certificate validation.
Affected Properties	Integrity, Availability
Assets at Risk	Brand Reputation, User Satisfaction, Delivery Parcels, User Data

Description An attacker positioned between the User App and the Backend API — through an untrusted Wi-Fi network, compromised user network path, malicious proxy, or weak TLS/certificate validation — performs a Man-in-the-Middle attack and modifies the real-time delivery tracking coordinates returned to the user. Instead of the real position of the drone or package, the attacker provides false coordinates, misleading the user about the actual delivery location or progress. The user may trust incorrect data, fail to detect that the package is being delivered elsewhere, or be unable to react in time, enabling package theft and causing loss of goods, customer distrust, and delivery disputes.

Impact Targeted package theft by misleading the legitimate recipient; brand-trust erosion and customer dissatisfaction caused by manipulated delivery tracking information.

Risk Assessment Likelihood: **Occasional** Impact: **High** Risk Score: **High**

***Rationale:** Public Wi-Fi MITM attacks are commodity attacks with widely documented tools. Damage reaches High because the attack directly enables package theft against individual customers. If TLS pinning is correctly enforced the residual risk would decrease significantly; High remains the conservative assessment until production validation is confirmed.*

Mitigation Protect User App–Backend API communication using HTTPS/TLS with strict certificate validation and certificate pinning in the mobile application. Tracking responses should include integrity protection through signed payloads or message authentication codes, timestamps, sequence numbers, and short validity windows. The application rejects stale, unsigned, duplicated, or inconsistent location updates. The backend validates tracking data against the expected route, delivery geofence, order status, and recent drone telemetry before returning it to the user. Suspicious tracking inconsistencies are logged and trigger alerts.

Threat #15 — Sensor Data Manipulation

Threat #15 — Sensor Data Manipulation	
STRIDE Category	Tampering
Attacker Access Required	Physical access to drone, compromised sensor firmware, interference with the sensor bus, or directional RF/optical signal during flight (e.g. infrared against LiDAR, ultrasound against altimeter).
Affected Properties	Integrity
Assets at Risk	Drone, User Safety, NAS Safety, Delivery Parcels

Description An attacker manipulates the drone’s sensor inputs, compromises sensor firmware, interferes with the sensor communication bus, or physically affects sensors during flight or landing. The attacker may provide false or distorted readings from IMU, barometer, altimeter, camera, obstacle-detection systems, magnetometer, or landing-zone sensors. The controller may therefore make incorrect navigation, stabilization, collision-avoidance, landing, or delivery decisions, potentially causing route deviation, unsafe landing, mission abort, failed delivery, package loss, or drone damage.

Impact Direct operational safety risk including crash or hard landing; environmental safety event; mission failure and potential package loss.

Risk Assessment Likelihood: **Uncommon** Impact: **High** Risk Score: **High**

Rationale: *Likelihood remains Uncommon because the attack generally requires either physical access or specialised RF/optical equipment together with knowledge of drone internals. Damage reaches High because manipulated sensor data can directly influence safety-critical flight decisions and may result in collision, injury, or mission failure. Existing sensor-fusion mechanisms significantly reduce residual risk.*

Mitigation Validate sensor data before using it for flight-control or delivery decisions. Apply sensor fusion, range checks, plausibility checks, and consistency validation across independent

sensors including IMU, barometer, vision systems, obstacle detection, and mission-route data. The controller rejects or downgrades sensor readings that are physically impossible, inconsistent with recent telemetry, or outside expected mission conditions. Protect sensor firmware and calibration data using signed firmware, secure boot where supported, and restricted update or calibration access. Monitor sensor communication for abnormal values, missing data, sudden jumps, or repeated inconsistencies. On suspected manipulation the drone enters a safe fallback mode: hover, slow down, request GCS confirmation, abort the delivery, return to base, or perform a controlled safe landing.

Threat #17 — Unauthorized Access / Privilege Escalation — GCS

Threat #17 — Unauthorized Access / Privilege Escalation — GCS	
STRIDE Category	Elevation of Privilege
Attacker Access Required	Stolen operator credentials, compromised workstation, malware, weak access controls, or misuse of low-privileged GCS account.
Affected Properties	Confidentiality, Integrity, Availability
Assets at Risk	Drone, User Data, Delivery Parcels, Brand Reputation, User Safety, FAA Certification, Credentials

Description An attacker with initial limited access to the GCS — through stolen operator credentials, compromised workstation, malware, weak access controls, or misuse of a low-privileged GCS account — escalates privileges and gains access to functions they should not be authorized to use. The attacker may obtain operator, administrator, or mission-control privileges and perform restricted actions such as modifying delivery missions, accessing order details, sending commands to drones, changing configuration settings, or disabling security controls. The attack may compromise the integrity and safety of drone operations, enabling misdelivery, package theft, operational disruption, unauthorized disclosure of sensitive data, or loss of control over active missions.

Impact Loss of operational control over active missions; data breach; potential operational safety event if unsafe commands are issued; plausible regulatory investigation and reputational damage.

Risk Assessment Likelihood: **Occasional** Impact: **Critical** Risk Score: **Critical**

Rationale: *Likelihood remains Occasional because insider threats, credential theft, and workstation compromise are realistic and commonly observed enterprise attack vectors. Damage reaches Critical because privileged GCS access can bypass or disable multiple defence layers*

and may cascade into operational safety incidents, package theft, data exposure, and regulatory consequences.

Mitigation Enforce strong access control on the GCS using multi-factor authentication, RBAC, least privilege, and separation of duties between operators, administrators, and observers. Privileged actions such as modifying missions, changing delivery destinations, sending emergency commands, or altering GCS configuration require re-authentication and are limited to explicitly authorized roles. Harden the GCS workstation through security patching, endpoint protection, disabling unnecessary services, and prevention of unauthorized software execution. Log all privileged actions together with user identity, timestamp, mission identifier, and command details. Monitor for abnormal access patterns or privilege escalation attempts using IDS or behavioural analytics. Use session timeouts, account lockout policies, secure credential storage, and periodic access reviews.

Threat #18 — Unauthorized Access / Privilege Escalation — Drone Controller

Threat #18 — Unauthorized Access / Privilege Escalation — Drone Controller	
STRIDE Category	Elevation of Privilege
Attacker Access Required	Vulnerable firmware interface, exposed debug port (JTAG/UART/SWD), compromised update mechanism, weak command authentication, malicious physical access, or software vulnerability exploitation.
Affected Properties	Confidentiality, Integrity, Availability
Assets at Risk	Drone, User Safety, NAS Safety, Delivery Parcels, FAA Certification

Description An attacker with initial limited access to the drone controller — through a vulnerable firmware interface, exposed debug port, compromised update mechanism, weak command authentication, malicious physical access, or exploitation of a software vulnerability — escalates privileges and gains access to restricted controller functions. The attacker may obtain administrative or flight-control privileges and perform actions normally reserved for trusted firmware, authorized GCS commands, or safety-critical control logic. The attack may alter flight parameters, bypass safety checks, modify mission behaviour, disable security controls, access sensitive telemetry, or issue unauthorized control commands, potentially causing route deviation, package theft, mission failure, unsafe flight behaviour, or total loss of control over the drone.

Impact Full compromise of a single airframe; potential cascading impact if the vulnerability propagates through OTA updates, shared firmware components, or supply-chain channels.

Risk Assessment Likelihood: **Uncommon** Impact: **Critical** Risk Score: **Critical**

***Rationale:** Likelihood remains Uncommon because drone-controller compromise generally requires significant technical capability, firmware exploitation expertise, or physical access. Damage is Critical because a fully compromised controller can directly bypass safety mechanisms and control the aircraft. If exploitable via scalable channels such as OTA infrastructure or supply-chain compromise, the operational impact becomes even more severe.*

Mitigation Protect the drone controller using secure boot, signed firmware, firmware roll-back protection, and authenticated OTA updates. Disable or lock debug interfaces such as JTAG, UART, and SWD in production devices, and store cryptographic material inside secure elements or protected hardware storage. Enforce strong command authentication and authorization so that only trusted GCS or backend components can issue privileged commands. Apply least privilege inside the controller software by separating flight-control logic, telemetry handling, mission management, and update functionality. Validate all received commands and configuration changes against safety policies, geofences, and mission constraints. Use watchdogs, runtime integrity checks, remote attestation where possible, and tamper-evident logging to detect unauthorized modification or privilege escalation attempts.

Threat #21 — MITM — ADS-B Message Injection

Threat #21 — MITM — ADS-B Message Injection	
STRIDE Category	Tampering
Attacker Access Required	Software-defined radio capable of ADS-B transmission; ADS-B has no native authentication.
Affected Properties	Integrity, Availability
Assets at Risk	Drone, NAS Safety, User Safety, Delivery Parcels

Description An attacker capable of transmitting crafted RF messages or interfering with the ATC/ADS-B communication path injects forged air-traffic messages into the data received by the UTM System. The attacker may introduce false aircraft positions, fake altitude or speed values, duplicated aircraft identifiers, or misleading collision-risk information. The UTM System may therefore calculate incorrect airspace awareness, indirectly influencing the drone controller through mission planning or traffic advisories and causing unnecessary evasive maneuvers, mission delays, route deviation, mission abort, or unsafe behaviour.

Impact Forced unsafe maneuvers; route deviation; mission abort; cascading operational impact including delivery disruption or route-deviation-based package theft.

Risk Assessment Likelihood: **Occasional** Impact: **High** Risk Score: **High**

Rationale: *This represents a more active and impactful variant of ADS-B spoofing because the attacker injects crafted traffic data directly into downstream flight-planning logic. Damage reaches High because manipulated traffic information can influence detect-and-avoid behaviour and degrade NAS operational safety.*

Mitigation The UTM System does not blindly trust air-traffic messages received through ADS-B. Validate received messages against trusted and independent sources including additional ATC feeds, cooperative UTM data, GCS reports, onboard drone sensors, computer vision, radar, and previous trajectory history. Use message authentication and integrity protection wherever supported by protocol or infrastructure. Apply freshness checks, replay protection, rate limiting, and anomaly detection to identify suspicious traffic messages. If injected or inconsistent traffic data is suspected, the drone enters a conservative safety mode: request confirmation from GCS or UTM, increase separation margins, reroute safely, or return to base if reliable traffic awareness cannot be restored.

Threat #22 — Workstation Intrusion — Pre-Flight Checklist Tampering

Threat #22 — Workstation Intrusion — Pre-Flight Checklist Tampering	
STRIDE Category	Tampering
Attacker Access Required	Compromised OIC workstation, malware in the GCS HMI environment, or unauthorized access to the pre-flight checklist workflow.
Affected Properties	Integrity
Assets at Risk	Drone, User Safety, NAS Safety, Delivery Parcels, FAA Certification, Credentials

Description An attacker with access to the OIC workstation, the GCS HMI, or the pre-flight checklist workflow alters the result of the pre-flight inspection and airworthiness verification. The attacker may mark the drone as ready for flight even when inspection items failed, were skipped, or were never performed. The drone may therefore be authorized to start a mission despite hardware, battery, sensor, payload, weather, or configuration issues, increasing the likelihood of mission failure, unsafe flight, failed delivery, or physical damage.

Impact An unfit drone is launched despite unresolved operational or safety issues; cascading risk of crash, package loss, environmental damage, or in-flight emergency. Long-term exposure includes regulatory consequences if CAM gating or airworthiness controls are bypassed systematically.

Risk Assessment Likelihood: **Uncommon** Impact: **High** Risk Score: **High**

Rationale: *Likelihood remains Uncommon because the attack generally requires workstation compromise, insider misuse, or unauthorized workflow access, partially mitigated by managed corporate endpoints. Damage reaches High because bypassing airworthiness verification may directly enable unsafe flight conditions and compound downstream operational and regulatory consequences.*

Mitigation Require authenticated operator sessions, role-based authorization, and mandatory checklist completion before takeoff. Pre-flight inspection results must be digitally signed or integrity protected, timestamped, and bound to the drone identifier, mission identifier, operator identity, and checklist version. The GCS prevents mission launch if required checks are missing, failed, expired, or inconsistent with telemetry or maintenance status. Critical failures cannot be overridden by a single operator and require supervisor approval or maintenance clearance. All checklist changes, overrides, and approvals are recorded in an append-only audit trail.

3.2.4. Threat selection and Appendix reference

This chapter reports the main threats identified during the threat modelling activity, with particular focus on threats classified as *High* or *Critical* severity. These threats are discussed in the main body of the report because they have the greatest potential impact on safety, service availability, customer trust, regulatory compliance, or the overall Prime Air operating model.

The remaining threats, including lower-severity cases and supporting scenarios, are reported in Appendix A. This separation keeps the chapter focused on the most relevant risks while preserving the complete threat enumeration for traceability and review.

3.2.5. Risk Distribution Matrix

The matrix below plots all 23 identified threats on the Likelihood $\times$ Impact grid. The cell colour reflects the resulting Risk Score. The visualisation makes explicit the concentration of risk: most threats cluster in the Occasional and Uncommon rows, with the High and Critical columns dominated by GCS and drone-controller compromise scenarios and by RF-channel attacks on unauthenticated aviation protocols.

Likelihood ↓ / Impact →	Low	Medium	High	Critical
Frequent	#13	—	—	—
Occasional	#9, #19	#2, #3, #8, #14	#1, #10, #11, #21	#17
Uncommon	—	#7, #12, #20, #23	#4, #6, #15, #22	#5, #18
Rare	—	—	#16	—

Table 3.15: Threats plotted on the Likelihood $\times$ Impact matrix. Cell colour is the resulting Risk Score; threat identifiers refer to the numbering used in this chapter and in Appendix A.

Three threats reach *Critical* Risk Score and concentrate on privileged-access compromise (#17 GCS, #18 Drone Controller) and on the integrity of delivery details inside the GCS (#5). Eight further threats receive a *High* rating and span RF resilience (#1, #10, #11, #21), navigation and sensor integrity (#4, #6, #15), and the pre-flight workflow (#22). The remaining twelve, rated Medium or Low, are reported in Appendix A for traceability and completeness.

4 | Conclusion

This threat model identified 23 distinct threats across all six STRIDE categories. The distribution is balanced, with the highest-severity threats concentrated on components that combine human-controlled access with safety-critical capabilities, including the Ground Control Station (GCS), drone controller, delivery-area assessment, and pre-flight workflow. Additional concentration appears on RF-based communication channels that remain unauthenticated by aviation standards, such as ADS-B and GPS.

Three threats stand out as **Critical** and require immediate defence-in-depth mitigation: spoofing of delivery details inside the GCS (#5), unauthorized access to the GCS (#17) and Unauthorized Access to the Drone Controller (#18). The **High**-severity tier contains 8 threats spanning RF resilience, navigation integrity, sensor and actuator integrity, and the pre-flight checklist workflow.

Each Critical or High-severity threat is independently capable of compromising delivery integrity, operational continuity, or flight safety, and each is realistically achievable by an attacker with moderate resources, commodity tooling, or limited insider access.

Let's point out some key observations of the whole system modelled.

- **Amazon's CONOPS already addresses many threats natively.** Management-by-exception (limits exposure of interactive command channels), GNSS + non-GNSS backup (mitigates GPS jamming/spoofing), UTM + onboard SAA + ATC feeds (mitigates ADS-B attacks). These design choices substantially reduce residual risk relative to a naively designed UAS.
- **The principal residual risk is the human/credentials supply chain.** Insider threat at the GCS (#17), pre-flight workflow tampering by the OIC (#22), and credential management for OICs and flight assistants are the highest-leverage attack vectors. Cryptography alone cannot mitigate them — they require strong identity, dual control on critical actions, and tamper-evident audit logging.
- **ADS-B is structurally vulnerable [2].** It is unauthenticated by international aviation standard. Defences against ADS-B spoofing and message injection must be architectural (cross-validation with UTM, onboard sensors, multiple ATC feeds), not protocol-level — until the next-generation authenticated successor is adopted.
- **The delivery-area marker is the easiest physical attack on Prime Air.** Captured as #23: low attacker cost (a printed QR code), targeted theft, no safety event. Cryptographically-bound markers tied to mission ID and time window are the single

most effective control.

Adjacent attack surfaces are explicitly out of scope but worth listing for completeness: OTA firmware update channel, inter-drone deconfliction, fleet-to-ATC coordination, the dedicated flight-assistant role. Each is a credible vector for fleet-scale or systemic attacks that warrants a follow-up iteration.

To sum up, this threat model is an academic exercise based on publicly available documentation (Amazon's FAA submission). It does not have access to Amazon's internal security assessments, certifications, or operational telemetry. Several mitigations recommended here are likely already implemented; they are included for completeness and pedagogical clarity. The Likelihood scores reflect typical attacker capabilities, not specific intelligence about active threat actors targeting Prime Air. The boundary between Inherent risk and Residual risk is approximate and depends on assumed enforcement of the Amazon-native mitigations cited in the CONOPS.

A | Appendix A

Threat #2 — RF Jamming — ATC/ADS-B Air Traffic Data Channel

Threat #2 — RF Jamming — ATC/ADS-B Air Traffic Data Channel	
STRIDE Category	Denial of Service
Attacker Access Required	Physical proximity; commodity RF jammer tuned to ADS-B band (1090 MHz).
Affected Properties	Availability
Assets at Risk	Drone, NAS Safety, Delivery Parcels, Brand Reputation

Description An attacker with RF transmission capability near the drone’s operating area jams or interferes with the wireless air-traffic data channel used by the UTM System to receive ATC/ADS-B information. By overwhelming or disrupting the radio signal, the attacker prevents the UTM System from receiving reliable air-traffic updates (nearby aircraft position, altitude, speed, identification). The UTM System may calculate an incomplete or degraded mission plan, and the drone may lose part of its detect-and-avoid support.

Impact Degraded situational awareness for the UTM and downstream drone DAA logic; conservative rerouting; in worst case, mission abort. Risk is bounded by Amazon’s multi-source approach (cooperative UTM data, GCS-provided traffic, onboard sensors).

Risk Assessment Likelihood: **Occasional** Impact: **Medium** Risk Score: **Medium**

Rationale: *ADS-B is broadcast and unauthenticated; jamming is feasible with low-cost equipment. The damage is contained by UTM redundancy (multiple ATC feeds, onboard sensors, computer vision). No direct safety event in isolation, but contributes to a chain weakening situational awareness.*

Mitigation The UTM System does not rely exclusively on ATC/ADS-B for air-traffic awareness. Use redundant sources: additional ATC feeds, cooperative UTM data, GCS-provided traffic updates, onboard drone sensors, computer vision, and radar. Implement RF jamming detection by monitoring signal loss, packet loss, RSSI/SNR anomalies, and sudden degradation of ADS-B reception. When jamming or loss of air-traffic data is detected, the UTM System marks the air-traffic picture as degraded and provides conservative route planning or alerts to GCS and drone. Log all signal-loss and jamming indicators for later investigation.

Threat #3 — GPS Jamming

Threat #3 — GPS Jamming	
STRIDE Category	Denial of Service
Attacker Access Required	Physical proximity; low-power GPS jammer (€20–€200 online).
Affected Properties	Availability
Assets at Risk	Drone, User Satisfaction, Delivery Parcels

Description An attacker transmits radio interference near the drone’s operating area, jamming the GPS signals used by the GPS component and controller for navigation, positioning, route tracking, and delivery decisions. By overwhelming or disrupting the GPS signal, the attacker prevents the controller from receiving accurate location data. The drone may lose awareness of its current position, fail to follow the planned route, abort the delivery, return to base, enter a safe hover mode, or perform an emergency landing.

Impact Navigation availability loss; mission abort. Risk constrained by Amazon’s GNSS + non-GNSS backup architecture (IMU, barometer, magnetometer, visual odometry) explicitly described in CONOPS.

Risk Assessment Likelihood: **Occasional** Impact: **Medium** Risk Score: **Medium**

Rationale: *GPS jammers are widely available and illegal in most jurisdictions, but cheap to acquire. Amazon’s CONOPS explicitly addresses degraded-GNSS scenarios with non-GNSS backup, which materially reduces damage to operational disruption rather than safety event.*

Mitigation Detect GPS degradation or loss by monitoring signal strength, satellite count, positioning accuracy, sudden GPS dropouts, and inconsistencies between GPS and other sensors. Navigation should not rely only on GPS: use fallback sources (IMU, barometer, magnetometer, visual odometry, obstacle sensors, geofencing, last known valid position). On suspected jamming the drone enters a predefined safe mode: slow down, hover where safe, request GCS assistance, return to base using alternative navigation, or perform a controlled safe landing. Log GPS loss and suspected jamming events with timestamp, location, signal-quality indicators, and mission context for later investigation.

Threat #7 — MITM — Order Details Disclosure

Threat #7 — MITM — Order Details Disclosure	
STRIDE Category	Information Disclosure

Attacker Access Required	Compromised GCS network, intermediate gateway, malicious proxy, or weak transport security.
Affected Properties	Confidentiality
Assets at Risk	User Data, Delivery Parcels, Brand Reputation

Description An attacker observing communication between the Backend API and the GCS (compromised GCS network, intermediate gateway, malicious proxy, or weak transport security) performs a Man-in-the-Middle attack and intercepts the order details sent to the GCS: delivery destination, customer address, package information, delivery time window, order identifier, mission metadata. The attacker may use the stolen data to track or intercept the package, identify the delivery location, infer customer habits, or plan further attacks against the delivery process.

Impact Disclosure of customer PII and operational data; targeted physical interception of subsequent deliveries.

Risk Assessment Likelihood: **Uncommon** Impact: **Medium** Risk Score: **Medium**

Rationale: Modern TLS deployment makes likelihood Uncommon. Damage is moderate: PII + delivery metadata, GDPR-relevant if scaled. No direct safety implication.

Mitigation Protect Backend API-GCS communication using HTTPS/TLS or mTLS with strict certificate validation and device-bound certificates for authorized GCS instances. Only authenticated and authorized GCS components access order details for assigned missions. Use short-lived credentials, scoped authorization, and session expiration. Minimize the order data sent to the GCS — only what is required to execute the delivery — avoiding unnecessary customer PII or internal business metadata. Sensitive order details are not logged in plaintext on the GCS, backend, proxies, or monitoring systems. Apply monitoring, audit logging, and rate limiting to detect abnormal order access or data scraping.

Threat #8 — Jamming — Delivery-Area Environment Conditions

Threat #8 — Jamming — Delivery-Area Environment Conditions	
STRIDE Category	Tampering
Attacker Access Required	Physical proximity to delivery location; commodity RF transmitter or signal source affecting condition sensors.
Affected Properties	Availability, Integrity
Assets at Risk	Brand Reputation, Delivery Parcels, User Satisfaction

Description An attacker interferes with, jams, or manipulates the signals used by the drone to evaluate delivery-area conditions, causing the drone to receive false or incomplete landing-condition data. Since the system’s safety mechanism prevents landing when conditions are considered unsafe — and the OIC cannot override this safety decision per Amazon’s CONOPS — the attacker can make the system believe the landing area is unsuitable even when it is actually safe. The drone automatically aborts the delivery and returns to base, causing failed deliveries, service disruption, operational delays, customer dissatisfaction, and potential financial loss.

Impact Denial-of-delivery against specific customers; reputational damage if recurring on the same locations.

Risk Assessment Likelihood: **Occasional** Impact: **Medium** Risk Score: **Medium**

Rationale: *Likelihood Occasional — local, low-cost interference. Damage Medium — denial of delivery for a single customer at a time, no safety event.*

Mitigation The drone does not rely on a single external signal or condition source for landing-safety decisions. Validate delivery-area conditions using multiple independent sources: onboard sensors, computer vision, altitude sensors, obstacle detection, weather data, and backend/GCS mission context. Apply plausibility checks to detect inconsistent, missing, or suddenly changing condition data. When condition signals are jammed or unavailable, the drone distinguishes between “unsafe landing area” and “sensor/communication failure” and follows a defined safe fallback policy: hover briefly, retry the condition check, request GCS confirmation, select an alternate approved drop-off point, or return to base only after repeated failures. All aborted landings caused by suspicious or inconsistent condition data are logged and flagged for investigation.

Threat #9 — Jamming — Repudiation of Delivery Failure Cause

Threat #9 — Jamming — Repudiation of Delivery Failure Cause	
STRIDE Category	Repudiation
Attacker Access Required	Same as #8; relies on absence of tamper-evident logs.
Affected Properties	Non-repudiation
Assets at Risk	Brand Reputation, User Satisfaction

Description An attacker who interferes with delivery-condition signals may later deny having caused the failed delivery, especially if the system does not collect sufficient evidence about why the drone aborted the landing. Because the drone automatically returns to base when

landing conditions are considered unsafe, a malicious actor can intentionally trigger or simulate unsafe conditions and then claim that the failure was caused by normal environmental factors, sensor error, or system malfunction. The system may be unable to prove whether the delivery was aborted due to a genuine safety condition, jamming, signal manipulation, or malicious interference, leading to disputes, lack of accountability, and difficulty investigating repeated delivery failures.

Impact Disputes; difficulty investigating recurring failures; weak forensic chain.

Risk Assessment Likelihood: **Occasional** Impact: **Low** Risk Score: **Low**

Rationale: *Likelihood Occasional (anyone who triggers #8 may dispute the cause). Damage Low — operational/dispute, not safety. Easily mitigated with tamper-evident logging.*

Mitigation Maintain tamper-resistant audit logs for every delivery-condition decision: timestamp, drone ID, mission ID, sensor readings, signal-quality indicators, GPS/location context, condition-check results, abort reason, and operator actions, return-to-base trigger. Logs are integrity-protected using digital signatures, hash chaining, or append-only storage, and synchronised to a trusted time source. Drone, GCS, and backend correlate logs to reconstruct events and distinguish genuine unsafe landing conditions from signal loss, jamming, or suspicious manipulation. Repeated aborts in the same area or abnormal condition-signal patterns trigger investigation and operational alerts.

Threat #12 — Eavesdropping — Mission Plan

Threat #12 — Eavesdropping — Mission Plan	
STRIDE Category	Information Disclosure
Attacker Access Required	Monitoring the network path, compromising intermediate gateway, exploiting weak transport security, or accessing the drone communication environment.
Affected Properties	Confidentiality
Assets at Risk	User Data, Brand Reputation, Delivery Parcels

Description An attacker observing the communication between the UTM System and the drone controller (network monitoring, compromised intermediate gateway, weak transport security, access to drone communication environment) eavesdrops on the mission plan exchanged between these components. Although the mission plan is generated inside the system from User Data + Order Details (and thus is not a primary asset itself), the attacker may learn planned waypoints, flight path, delivery area, timing, altitude profile, route constraints — and indirectly expose customer location.

Impact Enables targeted physical interception or RF attacks along the known route; indirect exposure of customer location.

Risk Assessment Likelihood: **Uncommon** Impact: **Medium** Risk Score: **Medium**

Rationale: *Likelihood Uncommon (requires meaningful capability against drone subsystem communication). Damage Medium — primarily an enabler for downstream targeted attacks rather than direct harm.*

Mitigation Protect communication between UTM System and drone controller using encrypted and authenticated channels (TLS/mTLS where applicable). Only authorized drone controllers can request or receive mission plans, using device-bound credentials and scoped authorization for the assigned mission. Minimize the mission plan data transmitted — only the route information required by the controller, no unnecessary customer identifiers, full order details, or internal backend metadata. Mission plan messages are protected against unauthorized access and are not logged in plaintext on the UTM System, controller, proxies, or monitoring tools. Access to mission plan data is audited, and abnormal requests or repeated route lookups trigger alerts.

Threat #13 — Eavesdropping — ATC/ADS-B Traffic Data

Threat #13 — Eavesdropping — ATC/ADS-B Traffic Data	
STRIDE Category	Information Disclosure
Attacker Access Required	Software-defined radio with antenna (RTL-SDR — €25); ADS-B is broadcast in clear by design.
Affected Properties	Confidentiality
Assets at Risk	Brand Reputation

Description An attacker monitors RF communications in the drone’s operating area (software-defined radio, antenna, or other passive radio monitoring equipment) and eavesdrops on the air traffic data exchange between ATC/ADS-B and the UTM System. The attacker may learn nearby aircraft positions, airspace activity, UTM airspace awareness data, route constraints, flight context, or operational behavior of the drone delivery system. The attacker may then track drone activity, infer delivery routes or operating areas, plan physical interception, or support follow-up attacks.

Impact Reconnaissance enabler. Limited direct impact because ADS-B is broadcast information; valuable as input to other attacks.

Risk Assessment Likelihood: **Frequent** Impact: **Low** Risk Score: **Medium**

Rationale: *Likelihood Frequent: ADS-B is unencrypted by aviation regulation and trivially observable with a €25 SDR. Although the broadcast content is low-sensitivity in isolation (the information is published by design), the high frequency of exposure justifies a Medium Risk Score: it feeds reconnaissance for downstream attacks such as #1, #2, #10 and warrants continuous monitoring.*

Mitigation Where possible, protect air traffic data using authenticated and encrypted communication channels. Since ADS-B-style broadcasts cannot be made confidential under current standards, the drone minimizes sensitive information exposed through this channel: no customer data, order details, internal mission metadata, or unnecessary drone identifiers. Separate customer/order identifiers from broadcast operational identifiers; rotate non-essential identifiers where possible; correlate ADS-B data with trusted sources (UTM, GCS, onboard sensors). Monitor for abnormal tracking behavior or repeated observation of drone operations in sensitive areas.

Threat #14 — Eavesdropping — GCS↔Drone Communication

Threat #14 — Eavesdropping — GCS↔Drone Communication	
STRIDE Category	Information Disclosure
Attacker Access Required	SDR, antenna, packet sniffer near drone or GCS; tuned to drone communication frequency.
Affected Properties	Confidentiality
Assets at Risk	Drone, User Data

Description An attacker monitoring RF communications near the drone or GCS (SDR, antenna, packet sniffer, or radio monitoring equipment) eavesdrops on the command and telemetry data exchanged between GCS and drone controller. The attacker may learn drone position, mission status, route progress, command patterns, telemetry values, or delivery timing. The intercepted data may then be used to track the drone, infer the delivery route, identify suitable interception points, learn operational behavior, or prepare follow-up attacks (replay, spoofing, command injection, targeted jamming).

Impact Reconnaissance; enables follow-up active attacks.

Risk Assessment Likelihood: **Occasional** Impact: **Medium** Risk Score: **Medium**

Rationale: *Likelihood Occasional — RF sniffing is technically feasible with SDR. Damage Medium — enables many downstream attacks but does not directly cause harm.*

Mitigation Protect the GCS–drone communication link using encryption and mutual authentication appropriate to the drone communication protocol. Use mission-specific session keys, secure pairing between GCS and drone, and key rotation to avoid long-term static credentials. Avoid transmitting customer PII, full order details, or unnecessary mission metadata over the RF link. Apply frequency hopping or spread spectrum techniques to reduce passive interception opportunities. Monitor for suspicious RF activity. Telemetry and command logs do not store sensitive data in plaintext; intercepted or failed authentication attempts are logged for investigation.

Threat #16 — Actuator Data Manipulation

Threat #16 — Actuator Data Manipulation	
STRIDE Category	Tampering
Attacker Access Required	Compromise of actuator firmware, wiring access, ESC control logic compromise, or low-level control-signal manipulation.
Affected Properties	Integrity
Assets at Risk	Drone, User Safety, NAS Safety, Delivery Parcels

Description An attacker with access to the communication path between the drone controller and actuators, or with the ability to compromise actuator firmware, wiring, ESC control logic, or low-level control signals, manipulates the commands sent from the controller to actuators. The attacker may alter motor speed commands, servo positions, payload release commands, or other actuator instructions before execution. The drone may therefore behave differently from the intended flight-control decision, including unstable flight, route deviation, failed landing, premature or incorrect package release, mission failure, physical damage, or unsafe behavior.

Impact Direct operational safety risk including crash or premature payload release; package loss; physical drone damage and mission failure.

Risk Assessment Likelihood: **Rare** Impact: **High** Risk Score: **Medium**

Rationale: *Likelihood remains Rare because the attack generally requires deep internal access, supply-chain compromise, or physical tampering with low-level control systems. Rare × High maps to Medium under the safety-conservative matrix; the residual risk is further reduced by Amazon’s runtime safety checks and watchdogs on actuator commands.*

Mitigation Authenticate and validate actuator control commands wherever technically feasible. Apply strict bounds checking on motor speed, servo movement, payload release, and other

actuator values. The controller rejects commands that are physically impossible, outside safe operating limits, inconsistent with the current flight phase, or misaligned with the approved mission state. Use signed firmware, secure boot, and rollback protection for actuator-related components such as ESCs and smart actuators. Protect internal communication buses and wiring against tampering, and restrict unauthorized firmware updates or calibration changes. Use watchdogs, runtime safety checks, redundant sensors, and independent safety logic to detect abnormal actuator behaviour and trigger safe fallback actions including stabilization, mission abort, return-to-base, or controlled landing.

Threat #19 — MITM — GPS Retrieval (User App ↔ Backend) — Disclosure

Threat #19 — MITM — GPS Retrieval (User App ↔ Backend) — Disclosure	
STRIDE Category	Information Disclosure
Attacker Access Required	Untrusted network, compromised router, malicious access point, proxy, or weakly protected communication channel.
Affected Properties	Confidentiality
Assets at Risk	User Data, Delivery Parcels, Brand Reputation

Description An attacker observing traffic between the User App and the Backend API (untrusted network, compromised router, malicious access point, proxy, or weakly protected communication) performs a Man-in-the-Middle attack and intercepts the real-time delivery tracking data exchanged between backend and the user's app. By reading the tracking coordinates, the attacker may learn the current position of the drone or package, the delivery progress, and potentially the expected drop-off location. The attacker may then physically intercept the delivery, steal the package, monitor delivery activity, or expose the customer's location.

Impact Real-time location exposure of customer and drone; package theft enabler.

Risk Assessment Likelihood: **Occasional** Impact: **Low** Risk Score: **Low**

Rationale: *Likelihood Occasional: public Wi-Fi MITM is a commodity attack. Damage Low: real-time tracking exposure is sensitive but bounded in scope and duration to a single delivery. Occasional × Low maps to Low; the risk is acknowledged and addressed by TLS with certificate pinning.*

Mitigation Protect real-time tracking data in transit using HTTPS/TLS with strict certificate validation and certificate pinning in the mobile app. Only authenticated and authorized

users access tracking data for their own orders. Use short-lived access tokens, scoped authorization, and session expiration. Minimize the tracking information returned to the app by avoiding unnecessary telemetry (internal drone identifiers, full route details, battery status, mission metadata). Apply rate limiting and monitoring to detect abnormal tracking access. Sensitive tracking data is not logged in plaintext on the client, backend, proxies, or analytics systems.

Threat #20 — MITM — GPS Retrieval (GCS ↔ Backend) — Disclosure

Threat #20 — MITM — GPS Retrieval (GCS ↔ Backend) — Disclosure	
STRIDE Category	Information Disclosure
Attacker Access Required	Compromised GCS network, intermediate gateway, malicious proxy, or weakly protected communication.
Affected Properties	Confidentiality
Assets at Risk	User Data, Delivery Parcels

Description An attacker observing traffic between the GCS and the Backend API (compromised GCS network, intermediate gateway, malicious proxy, or weakly protected communication) performs a Man-in-the-Middle attack and reads the GPS telemetry exchanged between Backend and GCS. By accessing this data, the attacker may learn the real-time position of the drone or package, the delivery progress, and potentially the expected drop-off area. The attacker may then physically intercept the package, monitor delivery operations, infer customer location, or plan further attacks against the drone delivery process.

Impact Real-time operational telemetry exposure; enables targeted interception.

Risk Assessment Likelihood: **Uncommon** Impact: **Medium** Risk Score: **Medium**

Rationale: Backend-side path is harder to attack than user-side (#19); damage Medium as operational data exposure enables physical interception.

Mitigation Protect GPS telemetry in transit between GCS and Backend API using HTTPS/TLS or mTLS with strict certificate validation and authenticated GCS certificates. Only authorized GCS instances may submit or access telemetry for assigned missions. Use short-lived credentials, scoped authorization, and session expiration. Minimize transmitted telemetry to what is strictly required, avoiding unnecessary exposure of internal drone identifiers, full mission metadata, or customer information. Sensitive telemetry is not logged in plaintext on the GCS,

backend, proxies, or monitoring systems. Apply monitoring and rate limiting to detect abnormal telemetry access or scraping behavior.

Threat #23 — Delivery Area Marker Spoofing

Threat #23 — Delivery Area Marker Spoofing	
STRIDE Category	Spoofing
Attacker Access Required	Physical access to the delivery area or its surroundings; a printed/displayed fake marker.
Affected Properties	Authenticity, Integrity
Assets at Risk	Delivery Parcels, User Data, Brand Reputation, User Satisfaction

Description An attacker with physical access to or proximity to the delivery area places, replicates, modifies, or displays a fake delivery-area marker that resembles the legitimate unique marker used by the drone to identify the correct drop-off location. During the delivery phase, the drone may detect the spoofed marker and incorrectly treat it as the authorized delivery area. The drone may land or release the package at an attacker-controlled location, causing misdelivery, package theft, customer disputes, and loss of trust in the delivery system.

Impact Targeted package theft at a known delivery address (e.g. a neighbour). Low effort, high return per attempt.

Risk Assessment Likelihood: **Uncommon** Impact: **Medium** Risk Score: **Medium**

Rationale: *Likelihood Uncommon — requires marker template and timing of the delivery window, but not technical sophistication. Damage Medium — theft of a single package per attack, no safety event. Severity Medium because it is the easiest physical attack on the delivery phase and may motivate scalable abuse.*

Mitigation The drone does not rely only on visual recognition of the delivery marker to authorize package release. The marker is cryptographically bound to the specific order, delivery location, time window, and mission ID — for example through a signed QR code, encrypted token, or challenge-response mechanism. The drone validates the marker against backend/GCS-provided delivery data, GPS/GNSS location, geofence, expected delivery area, and visual/landing-zone checks before accepting it. Markers are single-use or time-limited to reduce replay risk. If the marker is missing, duplicated, expired, inconsistent with the expected geofence, or detected in multiple nearby locations, the drone refuses delivery and enters a safe fallback mode.

List of Figures

1.1	Amazon Prime Air Drone.	1
1.2	Amazon Prime Air Mission Lifecycle Diagram. Source: [1].	2
2.1	Threat Model Visual Representation	6

Bibliography

- [1] Amazon.com Services, Inc. Amazon prime air — petition for exemption under 49 u.s.c. § 44807 and 14 c.f.r. parts 61, 91, and 135. Petition submitted to the U.S. Department of Transportation, Docket Management Facility, Docket No. FAA-2019-0573, July 2019. Submitted by Sean Cassidy, Director of Safety & Regulatory, Amazon Prime Air. Available via FDMS at <https://www.regulations.gov/document/FAA-2019-0573-0001>.
- [2] G. Digregorio, E. Saputelli, S. Longari, M. Carminati, and S. Zanero. Swarm: A distributed ledger-based framework to enhance air traffic control security using ads-b protocol. *ACM Trans. Priv. Secur.*, 28(4), Sept. 2025. ISSN 2471-2566. doi: 10.1145/3759456. URL <https://doi.org/10.1145/3759456>.
- [3] V. Sihag, G. Choudhary, P. Choudhary, and N. Dragoni. Cyber4drone: A systematic review of cyber security and forensics in next-generation drones. *Drones*, 7(7):430, 2023. doi: 10.3390/drones7070430. URL <https://doi.org/10.3390/drones7070430>.